

タイトル: MOVEit データ漏洩事件における Web API の SQL インジェクション攻撃と対策

1. はじめに

近年、Web API は様々なソフトウェアやサービス間でデータを効率的にやり取りするための重要な技術となっている。しかし、API のセキュリティが不十分である場合、攻撃者による不正アクセスや情報漏洩のリスクが高まる。特に SQL インジェクションは、API を通じてデータベースに悪意のある命令を送り、機密情報を取得したり改ざんしたりする代表的な攻撃手法である。本レポートでは、2023 年に発生した MOVEit データ漏洩事件を事例に挙げ、SQL インジェクションの攻撃内容とその対策について考察する。

2. MOVEit データ漏洩事件の概要

2023 年 5 月、アメリカの Progress Software 社が開発した MOVEit Transfer というデータ転送プラットフォームで大規模な情報漏洩事件が発生した。MOVEit Transfer は多くの政府機関や銀行、大学などが利用している安全なファイル転送システムである。しかし、その Web API に存在した SQL インジェクションの脆弱性を攻撃者が悪用し、多数のユーザーの個人情報や財務データが流出した。攻撃者は、API のリクエストに悪意ある SQL コードを挿入し、サーバーのデータベースに不正にアクセスした。これにより、ユーザーのアカウント情報やパスワード、銀行情報などの機密データを取得し、不正利用が行われた。

3. SQL インジェクションの特徴と影響

SQL インジェクションは、API に送信される入力値が適切に検証されていない場合に発生する。攻撃者は入力フォームや API パラメータに悪意のある SQL 文を挿入し、データベースの情報を取得または改ざんすることが可能である。MOVEit 事件では、この攻撃により世界中の数千万の個人情報が危険にさらされた点が特に重大である。

4. 対策案

この種の攻撃を防ぐためには、以下の対策が重要である。

パラメータ化クエリの利用：SQL 文とデータを分離し、ユーザー入力が SQL 文として解釈されることを防ぐ。入力値の厳格な検証とサニタイズ：API に渡されるデータを検証し、不正な文字列やコマンドを除去する。権限管理の強化：必要最低限の権限しか持たないユーザーアカウントで DB アクセスを行う。定期的なセキュリティテスト：脆弱性診断やペネトレーションテストで問題点を早期発見し対応する。監査ログの活用：不正アクセスの兆候を検知できるようにログを収集・分析する。

5. おわりに

MOVEit データ漏洩事件は、最新の Web API 環境においても基本的なセキュリティ対策がいかに重要であるかを示すものである。今後も API の安全性を確保するため、開発者と運用者は継続的な対策と監視を行う必要がある。

参考資料：

ZDNet Japan, 「MOVEit Transfer で大規模情報漏洩、SQL インジェクションが原因」 2023 年
OWASP, 「SQL Injection」 https://owasp.org/www-community/attacks/SQL_Injection
Progress Software, 「MOVEit Transfer Security Advisory」 2023 年